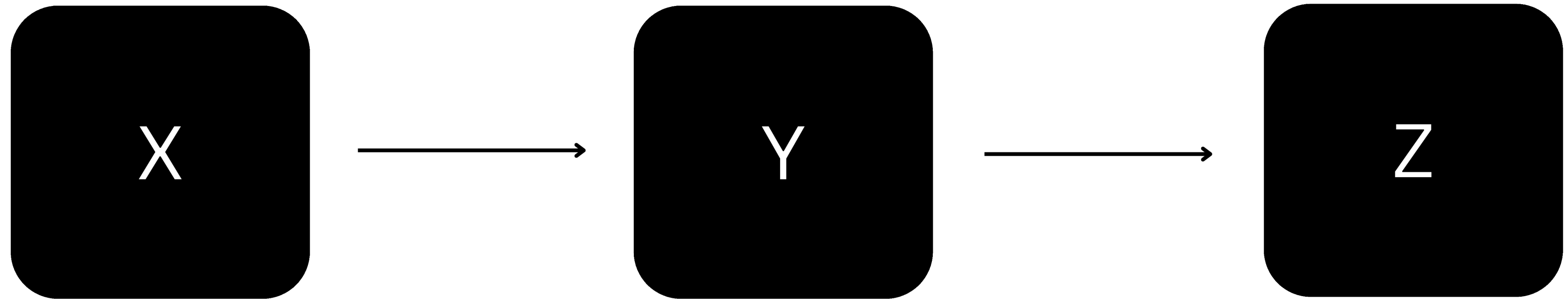


Threat models based on the discussion last time: Case 1

Description: z is dependent on y, and y is dependent on x



Identities of actors:

X: producer of software

Y: distributor of software

Z: user of software

Threat:

What if Z receives a modified version of X's SBOM from Y?.

Proposed solution:

Have X sign the SBOM, and have Z verify it using a public key. To ensure that the public key itself has not been tempered with, have a central database of public keys to access the public key from.

Threat models based on the discussion last time: Case 2

Description: z is dependent on y, and y is dependent on x



Identities of actors:

X: A package

Y: A negligent package

Z: Caller of SBOM function

Threat:

Y fails to self report all of its dependencies, and leaves some dependencies unreported.

Proposed solution:

Use omnibor as a pre-processing step in generating an SBOM instead of generating an SBOM based solely all of self reported dependencies.